Exposure audit checklist — for organizations without a security team

Version: 1.0 · **Turn:** 001 · **Date:** 12 November 2026 **Built for:** a school district, clinic, nonprofit or small manufacturer with one to three IT staff and no dedicated security role. **Time to first result:** two hours for Phase 0–2. Full audit: two to three days spread across two weeks.

How to use this

Work the phases in order. Each item has a checkbox, a way to verify it, and a pass criterion. Record the result in the evidence log at the end, not in your head.

Scoring. Score every control 0, 1 or 2.

- **0 — absent.** No control, or nobody knows whether it exists.
- **1 — partial.** Something exists but is undocumented, inconsistent or untested.
- **2 — in place and tested.** Documented, working, and verified in the last twelve months.

A score of 80% or better across the ten phases is a defensible baseline for a small organization. Anything below 60% means the next incident is likely to become a data-loss event, not just an outage.

Rules of engagement. Only audit systems your organization owns or has written authority to test. Do not port-scan a vendor, an ISP or a partner. Prefer read-only checks. If you find evidence of an active compromise at any point, stop the audit, preserve logs, isolate the system and move to Phase 8.

Phase 0 — Scope and authority (30 minutes)

- [ ] **Name one owner.** A single person accountable for the audit, even if they do not do every task. *Verify:* their name is written at the top of the evidence log. *Pass:* one name, not a committee.
- [ ] **Write the scope.** List every site, cloud tenant, domain and subsidiary in scope. *Verify:* compare against the insurance policy and the ISP bill; both list locations people forget. *Pass:* nothing in scope is described as “probably not ours”.
- [ ] **Get written authorization.** An email from leadership is enough. *Verify:* the email is saved in the evidence folder. *Pass:* you can show it if a vendor or insurer asks.

- [ ] **Set the rules.** No destructive testing, no password cracking, no social engineering without sign-off. *Verify:* rules are written in the scope document. *Pass:* every participant has read them.
- [ ] **Open an evidence folder.** One folder, one naming convention: `YYYY-MM-DD_phase_item`. *Verify:* the first screenshot is saved. *Pass:* a stranger could reconstruct what you checked.

Phase 1 — Know what you have (2–3 hours)

- [ ] **Asset inventory.** Every server, endpoint, network device, cloud subscription and domain, with an owner. *Verify:* reconcile the list against DHCP leases, the domain registrar, the cloud billing console and the switch ARP table. *Pass:* no device with an IP address lacks an owner.
- [ ] **The five-vendor check.** Search your inventory, invoices and support contracts for Barracuda, Ivanti, Fortinet, PHP and Zammad. These five account for 10 of the 31 forensic-triage entries in the current CISA catalog. *Verify:* one line per product found, with version and support status. *Pass:* every hit has a named administrator and a patch path.
- [ ] **Remote access map.** Every way into the network: VPN, RDP, remote support tools, cloud desktops, vendor tunnels. *Verify:* compare against firewall rules and the helpdesk's remote-support tool. *Pass:* every entry point has MFA or a documented exception.
- [ ] **Shadow IT sweep.** Ask five staff which apps they use that IT did not install. *Verify:* check the expense report for SaaS subscriptions. *Pass:* every paid app appears in the inventory.
- [ ] **Data map, one page.** Where the regulated and sensitive data lives: student records, patient records, payroll, donor data, intellectual property. *Verify:* walk it through with the person who actually uses each system. *Pass:* you can name the system, the owner and the retention rule for each data set.
- [ ] **End-of-life list.** Software and hardware no longer receiving security updates: old Windows Server, unsupported PHP, ageing firewalls, that NAS from 2016. *Verify:* vendor lifecycle pages. *Pass:* every EOL item has a replace-or-isolate decision and a date.

Phase 2 — Outside-in exposure (2 hours)

- [ ] **Domain and DNS inventory.** Every public domain, subdomain and mail record. *Verify:* certificate transparency logs and the registrar's DNS panel. *Pass:* no forgotten subdomain points at a decommissioned server.

- [ ] **Exposed admin panels.** Check whether firewalls, VPNs, hypervisors, backup consoles and printers are reachable from the internet. *Verify:* connect from a phone on cellular data, not from inside the office. *Pass:* administrative interfaces are behind VPN or an IP allow-list.
- [ ] **TLS certificate hygiene.** No expired certificates, no TLS 1.0/1.1, no self-signed certificates on public services. *Verify:* browser padlock and an SSL test. *Pass:* every public service scores an A or B.
- [ ] **Email authentication.** SPF, DKIM and DMARC published, with DMARC at `p=quarantine` or `p=reject`. *Verify:* send a test message and read the headers; check the public DNS record. *Pass:* DMARC is enforcing, not `p=none`.
- [ ] **Cloud tenant exposure.** Public file links, guest accounts, legacy protocols (POP/IMAP/SMTP AUTH), forwarding rules to external addresses. *Verify:* tenant admin centre reports. *Pass:* no anonymous sharing links on sensitive folders.
- [ ] **Search for your own credentials.** Check whether staff email addresses appear in known breach corpora. *Verify:* a reputable breach-check service, using a work address with permission. *Pass:* every hit triggers a password reset and MFA check.

Phase 3 — Identity and access (2 hours)

- [ ] **MFA everywhere it matters.** Email, VPN, remote support, cloud admin, finance and payroll. *Verify:* sign in and observe the prompt. *Pass:* no account with administrative access lacks MFA.
- [ ] **Privileged account inventory.** Domain admins, global admins, firewall admins, backup admins. *Verify:* export the groups and compare to the staff list. *Pass:* fewer than five standing domain admins, each with a named owner.
- [ ] **Separate admin accounts.** Staff use a different account for daily work than for administration. *Verify:* ask two admins to show their login screen. *Pass:* no one browses email as domain admin.
- [ ] **Password manager.** Every staff member has one, and shared credentials live in it, not in a spreadsheet. *Verify:* count active seats against headcount. *Pass:* no shared password document on the file server.
- [ ] **Joiner-mover-leaver process.** A checklist that removes access on the last day. *Verify:* pick three recent leavers and confirm their accounts are disabled. *Pass:* all three are disabled, with the date recorded.
- [ ] **Session and token hygiene.** Revoke stale VPN sessions, OAuth app grants and API tokens quarterly. *Verify:* review the tenant's enterprise applications list. *Pass:* every third-party app grant has an owner and a reason.

Phase 4 — Patch and vulnerability management (2 hours)

- [ ] **Edge devices first.** Firewalls, VPN concentrators, email gateways and load balancers patched before anything else. *Verify:* compare installed versions against the vendor's latest advisory. *Pass:* no edge device is more than one security release behind.
- [ ] **KEV check.** Search the CISA Known Exploited Vulnerabilities catalog for every product in your inventory. *Verify:* the catalog is searchable and downloadable as JSON or CSV. *Pass:* every match has a remediation date, with edge devices first.
- [ ] **Web stack versions.** WordPress core, plugins, PHP and any CMS. *Verify:* the admin dashboard and a `phpinfo` page on a staging host only. *Pass:* WordPress on the current release, PHP on a supported branch, no abandoned plugins.
- [ ] **Browser and endpoint updates.** Automatic updates enabled, with a report showing compliance. *Verify:* the management console's patch compliance report. *Pass:* 95% of endpoints on the current browser major version.
- [ ] **Compensating controls for unpatchable systems.** For EOL or vendor-locked systems: network segmentation, IP allow-listing, web server disabled, read-only file shares. *Verify:* a network diagram showing the isolation. *Pass:* every unpatchable system sits in its own segment with a documented exception.
- [ ] **Patch cadence written down.** Who approves emergency patches, and how fast. *Verify:* the change-management policy names a KEV exception path. *Pass:* an edge-device patch can ship in 72 hours without a full change board.

Phase 5 — Email and phishing (1 hour)

- [ ] **Gateway configuration.** External sender warning banners, attachment sandboxing, blocked executable types, DMARC enforcement. *Verify:* send test messages from an external account. *Pass:* a spoofed internal email is quarantined.
- [ ] **Phishing reporting.** A one-click report button that reaches IT, and a process for what happens next. *Verify:* send a simulated phish to ten staff. *Pass:* at least half report it, and the reports are triaged.
- [ ] **Training cadence.** Security awareness training at onboarding and annually, with short quarterly simulations. *Verify:* completion records. *Pass:* 90% completion, including leadership.
- [ ] **Payment-change verification.** A call-back rule for any change to bank details, with a known number. *Verify:* finance can recite the rule. *Pass:* no email-only bank-detail changes are accepted.

Phase 6 — Backup and recovery (2 hours, plus one restore test)

This phase matters more than any other in the current threat landscape. SafePay operators halt Volume Shadow Copy and factory-reset NAS devices before they encrypt, so the backup you can see from the domain is often the first thing taken.

- [ ] **3-2-1 rule.** Three copies, two media types, one off-site. *Verify:* count the copies and name the locations. *Pass:* at least one copy is physically or logically separated from the production network.
- [ ] **Immutable or offline copy.** Object lock, tape, or a drive that is disconnected when not in use. *Verify:* try to delete a backup from a domain admin account. *Pass:* the deletion fails or requires a separate credential.
- [ ] **The NAS test.** The backup appliance is not domain-joined, not reachable over SMB from user VLANs, and not administered with the same account as endpoints. *Verify:* check domain membership and firewall rules. *Pass:* all three are true.
- [ ] **Restore test, timed.** Restore one critical system to isolated hardware and write down the duration. *Verify:* the test is recorded in the evidence log. *Pass:* restore time is inside your tolerance, and the data is usable, not just present.
- [ ] **Backup credentials.** Separate from domain credentials, stored in the password manager or a sealed envelope. *Verify:* the backup admin can restore without a domain admin. *Pass:* no single account controls both production and backups.
- [ ] **Retention and legal hold.** Retention matches policy and any litigation hold. *Verify:* compare the policy to the configured retention. *Pass:* the two match.

Phase 7 — Logging and detection (1 hour)

- [ ] **Thirty days of searchable logs.** Web server, VPN, email gateway and authentication logs, retained and searchable. *Verify:* search for a login from last month. *Pass:* the query returns results in under five minutes.
- [ ] **Time synchronization.** All systems use NTP, so logs line up. *Verify:* compare timestamps across two systems. *Pass:* drift under one minute.
- [ ] **Central log destination.** Logs survive if the source is encrypted or wiped. *Verify:* check whether a domain controller compromise would erase the evidence. *Pass:* at least one copy leaves the host.
- [ ] **Alerting that someone reads.** Failed-login spikes, new admin accounts, disabled antivirus, large outbound transfers. *Verify:* ask who receives the alert and when they last acted on one. *Pass:* a named person, a named channel, and a recent example.

- [ ] **Endpoint detection.** EDR or at least managed antivirus with tamper protection. *Verify:* the console shows all endpoints, including servers. *Pass:* coverage above 95%, with alerts triaged.

Phase 8 — Incident response (1 hour)

- [ ] **One-page plan.** Who calls whom, in what order, with after-hours numbers. *Verify:* print it and keep a copy offline. *Pass:* it fits on one page and names a decision-maker.
- [ ] **Contact list.** CISA Central, IC3, cyber insurer, legal counsel, MSP, key vendors. *Verify:* every number is current. *Pass:* you can reach a human at each within ten minutes.
- [ ] **Isolation procedure.** How to disconnect a system without destroying evidence. *Verify:* a technician can explain it without notes. *Pass:* pull-the-plug vs preserve-memory is a documented decision.
- [ ] **Reporting obligations.** Regulatory, insurer and law-enforcement reporting timelines for your sector. *Verify:* written into the plan. *Pass:* the clock starts when you know, and the plan says who owns it.
- [ ] **Tabletop exercise.** One 60-minute scenario in the last twelve months. *Verify:* attendance list and lessons learned. *Pass:* at least one change was made as a result.

Phase 9 — Vendors and MSPs (1 hour)

- [ ] **Vendor inventory.** Every vendor with remote access to your systems. *Verify:* compare the contracts to the firewall's allow-list. *Pass:* no vendor tunnel without a contract and an owner.
- [ ] **MFA on vendor access.** Vendors use named accounts with MFA, not shared local accounts. *Verify:* the VPN or remote-support console shows named users. *Pass:* no shared vendor credentials.
- [ ] **Incident notification clause.** The contract requires the vendor to tell you about a breach that affects your data, within a stated window. *Verify:* read the security addendum. *Pass:* the window is 72 hours or less.
- [ ] **MSP responsibilities.** Written split of who patches what, who monitors what, and who owns the backup. *Verify:* a responsibility matrix signed by both parties. *Pass:* no control is assumed to be "the MSP's job" without documentation.
- [ ] **Fourth-party risk.** Your MSP's own security posture and its subcontractors. *Verify:* ask for their latest SOC 2 or equivalent, and their incident history. *Pass:* you have a document less than twelve months old.

Phase 10 — People and governance (1 hour)

- [ ] **Board or leadership briefing.** A one-page quarterly report with the score, the top three risks and the decisions needed. *Verify:* the last meeting's minutes mention cyber risk. *Pass:* risk is on the agenda, not just in IT's head.
- [ ] **Policy set.** Acceptable use, access control, backup, incident response and vendor management, each dated and approved. *Verify:* the policy folder. *Pass:* every policy has an owner and a review date.
- [ ] **Insurance.** Cyber liability coverage confirmed, with the insurer's incident-response requirements written into the plan. *Verify:* the policy and the contact number. *Pass:* coverage limits and exclusions are understood by leadership.
- [ ] **Budget line.** A named annual figure for patching, backup, training and replacement of EOL systems. *Verify:* the budget document. *Pass:* security is funded as an operating cost, not a one-off project.
- [ ] **Succession.** More than one person can restore a backup, disable an account and contact the insurer. *Verify:* ask the deputy to do each task. *Pass:* no single point of human failure.

Scoring sheet

Phase	Controls	Score (0–2 each)	Max	Notes
0 Scope and authority	5		10	
1 Asset knowledge	6		12	
2 External exposure	6		12	
3 Identity and access	6		12	
4 Patch and vulnerability	6		12	
5 Email and phishing	4		8	
6 Backup and recovery	6		12	
7 Logging and detection	5		10	
8 Incident response	5		10	
9 Vendors and MSPs	5		10	
10 People and governance	5		10	
Total	**59**		**118**	

80% or above (95+): maintain and test annually. **60–79% (71–94):** fix the red flags first, then the backup and identity phases. **Below 60% (under 71):** treat as an active risk. Present the score to leadership this week and fund Phase 6 and Phase 3 before anything else.

Red flags — stop and fix this week

1. Backups are domain-joined or reachable over SMB from user VLANs.
2. No restore has ever been tested.
3. Administrative interfaces for VPN, firewall or backup are reachable from the internet without MFA.
4. A departed employee’s account is still active.
5. DMARC is `p=none` and nobody reads the reports.
6. Logs are retained for less than seven days.

7. An end-of-life internet-facing system has no isolation and no replacement date.

Any one of these can turn a patchable incident into an unrecoverable one.

Thirty, sixty, ninety

First 30 days. Fix the red flags. Enable MFA on email, VPN and admin accounts. Confirm an offline or immutable backup exists and run one timed restore. Patch the five-vendor list and every edge device.

Days 31–60. Build the asset inventory if it did not exist. Enforce DMARC. Turn on thirty-day log retention. Write the one-page incident plan and test the contact list. Retire or isolate one EOL system.

Days 61–90. Run a tabletop exercise. Add the vendor responsibility matrix. Present the score to leadership with a funded remediation plan. Schedule the next audit for twelve months out.

Evidence log template

```
Date | Phase | Control | Result (0/1/2) | Evidence file | Owner | Next ac
```

Keep one line per control. The log is what an insurer, a regulator or a forensic firm will ask for first.

Contacts for this checklist

- **CISA Central** — contact@cisa.dhs.gov · 1-844-Say-CISA (1-844-729-2472)
- **FBI IC3** — ic3.gov · 1-800-CALL-FBI (1-800-225-5324)
- **MS-ISAC SOC** (SLTT and school districts) — 1-866-787-4722 · soc@msisac.org
- **Emergency** — 911

Primary source for the KEV references: CISA Known Exploited Vulnerabilities catalog, version 2026.11.10.